

المرجع الخليجي الشامل في الأمن السيبراني

الأسس والضوابط والعمليات والتنظيم

علي العنزي

2026

المرجع الخليجي الشامل في الأمن السيبراني

علي العنزي

الطبعة الأولى 2026

جميع الحقوق محفوظة للمؤلف، فلا يجوز نسخ أي جزء من هذا الكتاب أو تخزينه أو نقله بأي وسيلة دون إذن كتابي مسبق منه، ويستثنى من ذلك الاقتباس القصير في المراجعات والدراسات مع الإشارة إلى المصدر.

للتواصل مع المؤلف: info@3li.info

المحتويات

xvii

المقدمة

1

الباب الأول: الأسس

3

1 مدخل إلى أمن المعلومات

1.1 ما المعلومات ولماذا نحميها 4

2.1 الخصائص الثلاث: السرية والسلامة والتوافر 5

3.1 أمن المعلومات والأمن السيبراني وحماية البيانات 8

4.1 المفردات الأربع: الأصل والتهديد والثغرة والخطر 8

5.1 مبادئ لا تتغير 9

6.1 أنواع الضوابط 11

7.1 لماذا تُخترق المؤسسات رغم كل هذا 12

8.1 الأمن عملية مستمرة لا منتج يُشتري 13

9.1	خلاصة الفصل	13
10.1	المصطلحات الأساسية	14
11.1	خريطة إلى الأطر	14
12.1	أسئلة للمراجعة	15
13.1	تمارين تطبيقية	15
2	التحديات والمهاجمون	17
1.2	من يهاجمنا ولماذا	18
2.2	تشريح الهجوم	19
3.2	الهندسة الاجتماعية	20
4.2	البرمجيات الخبيثة	22
5.2	هجمات الشبكات والأنظمة	23
6.2	التهديد الداخلي	24
7.2	مشهد التهديدات في الخليج	25
8.2	كيف يفكر المدافع	25
9.2	خلاصة الفصل	26
10.2	المصطلحات الأساسية	26
11.2	خريطة إلى الأطر	27
12.2	أسئلة للمراجعة	27

28 13.2 تمارين تطبيقية

3 إدارة المخاطر 29

30 1.3 لماذا نبدأ من الخطر لا من التقنية

31 2.3 خطوات إدارة المخاطر

32 3.3 جرد الأصول وتصنيفها

33 4.3 تحديد التهديدات والثغرات

34 5.3 تحليل المخاطر بين النوعي والكمي

35 6.3 معالجة المخاطر

36 7.3 شبيهة المخاطر وتحملها

36 8.3 سجل المخاطر الحي

37 9.3 مخاطر الأطراف الثالثة وسلسلة التوريد

38 10.3 المخاطر في سياقنا الخليجي

39 11.3 خلاصة الفصل

39 12.3 المصطلحات الأساسية

40 13.3 خريطة إلى الأطر

40 14.3 أسئلة للمراجعة

41 15.3 تمارين تطبيقية

4 الحوكمة والسياسات والأطر والامثال 43

1.4	ما الحوكمة ولماذا تفشل البرامج بدونها	44
2.4	أين يقع أمن المعلومات في الهيكل	45
3.4	هرم الوثائق	46
4.4	الأطر والمعايير الدولية	47
5.4	المشهد التنظيمي في الخليج	49
6.4	الامتثال ليس أمناً	51
7.4	قياس البرنامج وتقريره	52
8.4	التأكيد والتدقيق	52
9.4	خلاصة الفصل	53
10.4	المصطلحات الأساسية	53
11.4	خريطة إلى الأطر	54
12.4	أسئلة للمراجعة	54
13.4	تمارين تطبيقية	55

57 الباب الثاني: الضوابط التقنية

59	التشفير	5
60	1.5 ما يفعله التشفير وما لا يفعله	
60	2.5 التشفير المتماثل	

المحتويات

3.5	التشفير غير المتماثل	61
4.5	دوال التجزئة ورموز المصادقة	62
5.5	التوقيع الرقمي	62
6.5	البنية التحتية للمفاتيح العامة	63
7.5	تأمين النقل بروتوكول TLS	64
8.5	إدارة المفاتيح ودورة حياتها	65
9.5	التشفير في واقعنا	66
10.5	ما بعد الحوسبة الكمية	66
11.5	خلاصة الفصل	67
12.5	المصطلحات الأساسية	67
13.5	خريطة إلى الأطر	68
14.5	أسئلة للمراجعة	68
15.5	تمارين تطبيقية	69

6 الهوية والمصادقة وإدارة الصلاحيات 71

1.6	المصطلحات الأربعة	72
2.6	عوامل المصادقة	73
3.6	كلمات المرور ما زالت معنا	74
4.6	الدخول الموحد والاتحاد	75

5.6	نماذج التحكم في الوصول	75
6.6	إدارة الحسابات المميزة	76
7.6	دورة حياة الهوية	77
8.6	الدليل النشط وما حوله	77
9.6	انعدام الثقة	78
10.6	الهوية الرقمية الوطنية في الخليج	79
11.6	خلاصة الفصل	79
12.6	المصطلحات الأساسية	80
13.6	خريطة إلى الأطر	81
14.6	أسئلة للمراجعة	81
15.6	تمارين تطبيقية	82

7 أمن الشبكات 83

1.7	الشبكة من منظور المدافع	84
2.7	التجزئة والمناطق	85
3.7	الجدران النارية بأجياها	86
4.7	كشف التسلل ومنعه	86
5.7	الوصول عن بعد والشبكات الخاصة الافتراضية	87
6.7	أمن نظام أسماء النطاقات	88

7.7	الشبكات اللاسلكية	88
8.7	التحكم في الوصول إلى الشبكة والبروتوكولات القديمة . . .	89
9.7	الحماية من حجب الخدمة	90
10.7	مراقبة حركة الشبكة	90
11.7	الشبكة في المؤسسة الخليجية	91
12.7	خلاصة الفصل	91
13.7	المصطلحات الأساسية	92
14.7	خريطة إلى الأطر	92
15.7	أسئلة للمراجعة	93
16.7	تمارين تطبيقية	93

8 أمن الأنظمة ونقاط النهاية 95

1.8	التهيئة الآمنة والتحصين	96
2.8	إدارة الثغرات والتحديثات	97
3.8	من مكافحة الفيروسات إلى كشف نقاط النهاية والاستجابة	98
4.8	الامتياز على الجهاز	99
5.8	الأجهزة المحمولة	100
6.8	التشفير على الأجهزة والوسائط	100
7.8	التسجيل على مستوى النظام	101

8.8	الخوادم والبيئات الافتراضية	101
9.8	الأنظمة القديمة التي لا تموت	102
10.8	نقاط النهاية في المؤسسة الخليجية	102
11.8	خلاصة الفصل	103
12.8	المصطلحات الأساسية	103
13.8	خريطة إلى الأطر	104
14.8	أسئلة للمراجعة	104
15.8	تمارين تطبيقية	105

9 أمن التطبيقات والتطوير الآمن 107

1.9	أشهر ثغرات التطبيقات	108
2.9	دورة التطوير الآمنة	110
3.9	نمذجة التهديدات للتطبيقات	111
4.9	الاختبارات الأمنية للتطبيقات	112
5.9	أمن واجهات البرمجة	112
6.9	أمن سلسلة توريد البرمجيات	113
7.9	الأمن في خط التسليم المستمر	113
8.9	الحماية في زمن التشغيل	114
9.9	التطبيقات في المؤسسة الخليجية	114

10.9	خلاصة الفصل	115
11.9	المصطلحات الأساسية	115
12.9	خريطة إلى الأطر	116
13.9	أسئلة للمراجعة	117
14.9	تمارين تطبيقية	117

10 أمن الحوسبة السحابية 119

1.10	نماذج الخدمة والنشر	120
2.10	المسؤولية المشتركة	121
3.10	الهوية في السحابة	122
4.10	التهيئة الخاطئة وإدارة الوضع الأمني	123
5.10	الحاويات والخدمات المصغرة	123
6.10	حماية البيانات في السحابة	124
7.10	الشبكات السحابية	124
8.10	المراقبة والتسجيل في السحابة	125
9.10	أمن البرمجيات كخدمة	125
10.10	الحوكمة والامتثال والتوطين في الخليج	126
11.10	استراتيجية الخروج ومخاطر التركيز	126
12.10	خلاصة الفصل	127

127	13.10 المصطلحات الأساسية
128	14.10 خريطة إلى الأطر
129	15.10 أسئلة للمراجعة
129	16.10 تمارين تطبيقية

11 أمن البيانات والخصوصية 131

132	1.11 التصنيف أساس كل شيء
134	2.11 دورة حياة البيانات وضوابطها
135	3.11 منع تسريب البيانات
135	4.11 التشفير والإخفاء والترميز
136	5.11 النسخ الاحتياطي والإتلاف الآمن
136	6.11 مبادئ الخصوصية
137	7.11 تقييم الأثر على الخصوصية
138	8.11 خروقات البيانات والإبلاغ عنها
138	9.11 البيانات في المؤسسة الخليجية
139	10.11 خلاصة الفصل
139	11.11 المصطلحات الأساسية
140	12.11 خريطة إلى الأطر
141	13.11 أسئلة للمراجعة

141	14.11 تمارين تطبيقية
143	12 أمن الأنظمة الصناعية وإنترنت الأشياء
144	1.12 عالم مختلف بأولويات معكوسة
145	2.12 نموذج بيردو والمناطق والقنوات
146	3.12 البروتوكولات الصناعية
146	4.12 التهديدات على قطاعات المنطقة
147	5.12 الضوابط الأساسية
148	6.12 دراسة حالة: محطة تحلية افتراضية
149	7.12 المراقبة دون تعطيل
149	8.12 أمن إنترنت الأشياء
150	9.12 البنية التحتية الحيوية في الخليج
150	10.12 الاستجابة للحوادث في البيئات الصناعية
151	11.12 خلاصة الفصل
151	12.12 المصطلحات الأساسية
152	13.12 خريطة إلى الأطر
152	14.12 أسئلة للمراجعة
153	15.12 تمارين تطبيقية
155	عن المؤلف

المقدمة

تعيش مؤسساتنا ومعاملاتنا وذاكراتنا اليوم على هيئة بيانات، فحساب البنك رقم في قاعدة بيانات، والهوية الرقمية صف في سجل، والصورة الأخيرة لجدك ملف في خدمة سحابية لا تعرف أين تقع خوادمها، ولهذا صار أمن المعلومات شأنًا يخص كل إنسان ولم يعد حكراً على المختصين في غرف الخوادم.

كُتبت هذا الكتاب لأنني لم أجد المرجع العربي الذي كنت أتمنى أن أقرأه في بداية طريقي، فالمراجع الأجنبية غزيرة لكنها تخاطب واقعاً مختلفاً عن واقعنا، والمحتوى العربي متناثر بين ترجمات حرفية ومقالات متفرقة لا يجمعها خيط واحد، لذا حاولت أن أجمع في هذا الكتاب الأساس النظري والممارسة العملية والسياق التنظيمي لمنطقتنا الخليجية في عمل واحد متماسك.

يخاطب هذا الكتاب ثلاث فئات من القراء، فهو مدخل منظم لطالب الجامعة والمبتدئ الذي يريد أن يفهم المجال من جذوره، ومرجع عملي للمهندس والمحلل الذي يعمل في الميدان ويحتاج إلى تثبيت المفاهيم وربطها ببعضها، وخريطة واضحة للمدير والقيادي والمسؤول الحكومي الذي يتخذ قرارات تمس أمن مؤسسته دون أن يكون متخصصاً في التفاصيل التقنية، وقد كُتب ليكون مرجعاً تعتمده الجامعات في مقرراتها والجهات الحكومية في برامج التأهيل، فهو كتاب من الخليج إلى الخليج يحمل مصطلح المنطقة وأطرها وأمثلتها، ولذلك يبدأ كل فصل بأهداف تعلم محددة ويختتم بخلاصة وجدول للمصطلحات

وخريطة تربطه بالأطر الدولية والخليجية وأسئلة للمراجعة وتمارين تطبيقية تصلح للمحاضرة والورشة.

قسمت الكتاب إلى أربعة أبواب، يضع الباب الأول الأسس من مفاهيم وتهديدات ومخاطر وحوكمة، ويتناول الباب الثاني الضوابط التقنية من التشفير إلى الأنظمة الصناعية، ويعالج الباب الثالث العمليات والصمود من المراقبة إلى الاستجابة والتعافي، ويطل الباب الرابع على الآفاق في الذكاء الاصطناعي والمسيرة المهنية، فإن كنت مبتدئاً فاقراً الأبواب بترتيبها، وإن كنت ممارساً فاذهب مباشرة إلى الفصل الذي تحتاجه لأن كل فصل كُتب ليُقرأ مستقلاً مع إحالات إلى ما يرتبط به.

اعتمدت في الكتاب المصطلحات العربية المستقرة في منشورات الجهات التنظيمية الخليجية ما أمكن، وأثبت المصطلح الإنجليزي بين قوسين عند أول ورود له لأن القارئ سيصادفه في عمله اليومي وفي الوثائق الدولية، وتجد في آخر الكتاب مسرداً يجمع هذه المصطلحات بالعربية والإنجليزية.

وفي اختتام فإن هذا الكتاب جهد بشري قابل للخطأ والتحسين، فإن وجدت فيه خطأ أو كان لديك اقتراح فراسلني على info@3li.info وسأكون ممتناً لك، وأسأل الله أن ينفع به كل من قرأه.

الباب الأول

الأسس

الفصل الأول

مدخل إلى أمن المعلومات

أهداف التعلم: بعد دراسة هذا الفصل ستكون قادراً على:

- تعريف المعلومات وتمييزها عن البيانات والمعرفة وبيان سبب حمايتها
- شرح خصائص السرية والسلامة والتوافر والخصائص المكتملة لها بأمثلة
- التمييز بين أمن المعلومات والأمن السبراني وحماية البيانات
- استخدام مفردات الأصل والتهديد والثغرة والخطر والضابط استخداماً صحيحاً
- تصنيف الضوابط بطبيعتها ووظيفتها وشرح المبادئ الثابتة للحماية

في صباح يوم عمل عادي يصل مدير العمليات في شركة متوسطة إلى مكتبه فيجد شاشات الموظفين كلها تعرض رسالة واحدة تخبره بأن ملفات الشركة سُقرت وأن استعادتها تتطلب دفع مبلغ بعملة رقمية خلال ثلاثة أيام، فتتوقف الفواتير والرواتب والعقود دفعة واحدة، ويكتشف الجميع في تلك اللحظة أن الشركة لم تكن تباع منتجات فحسب بل كانت تقوم على معلومات لم يفكر أحد في حمايتها جيداً.

تتكرر هذه القصة كل يوم بأشكال مختلفة في المستشفيات والجامعات والجهات الحكومية والبنوك والمتاجر الصغيرة، وما يجمع بين ضحاياها ليس ضعف التقنية وحدها بل غياب الفهم المنظم لما ينبغي حمايته ومن يهدده وكيف تُبنى الحماية، ولهذا يبدأ هذا الكتاب من الأساس، أي من تعريف المعلومات وخصائصها التي نحميها والمفردات التي يتحدث بها المختصون والمبادئ التي لا تتغير مهما تغيرت التقنية.

1.1 ما المعلومات ولماذا نحميها

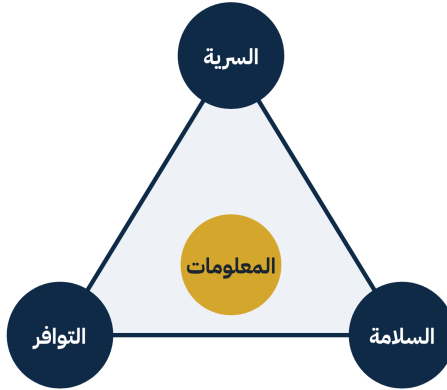
تبدأ الحكاية بالبيانات (Data) وهي حقائق خام لا معنى لها في ذاتها كرقم هاتف منفرد أو تاريخ أو مبلغ، فإذا رُتبت هذه البيانات في سياق صارت معلومات (Information) كأن نعرف أن هذا الرقم يخص عميلاً بعينه وأن ذلك المبلغ هو رصيده في تاريخ محدد، وإذا تراكت المعلومات وفسرت صارت معرفة (Knowledge) تُبنى عليها القرارات، ونحن نحمي المعلومات لأن لها قيمة، فقيمتها قد تكون مالية كبيانات البطاقات المصرفية، أو قانونية كالعقود والسجلات الطبية، أو تنافسية نخطط المنتجات وأسعار العطاءات، أو إنسانية كصور العائلة وأسرار المرضى، وقد تكون قيمتها في مجرد توافرها في اللحظة المناسبة كبيانات المريض على طاولة العمليات.

ولا تعيش المعلومات في الحاسوب وحده، فهي في الورق المطبوع وفي الأحاديث الجانبية وفي ذاكرة الموظفين وفي الرسائل النصية وفي الصور الملتقطة بالهاتف، ولهذا يتحدث المختصون عن حالات المعلومات الثلاث، أي المعلومات أثناء التخزين (At Rest) على الأقراص والنسخ الاحتياطية، وأثناء النقل (In Transit) عبر الشبكات والبريد، وأثناء الاستخدام (In Use) في ذاكرة

التطبيقات وعلى الشاشات، فالحماية التي تغطي حالة واحدة وتهمل الآخرين تشبه باباً محصناً في بيت بلا جدران.

كما تمر المعلومات بدورة حياة تبدأ بالإنشاء ثم التخزين ثم الاستخدام والمشاركة ثم الأرشفة ثم الإتلاف، ويحتاج كل طور من هذه الأطوار إلى حماية تناسبه، فالمعلومة التي أُلُفَت بطريقة غير صحيحة قد تعود للظهور من قرص بيع في سوق المستعمل، والمعلومة التي شُرِكت مع طرف ثالث خرجت من نطاق سيطرتك ما لم تضبط هذه المشاركة بعقد وضوابط.

2.1 الخصائص الثلاث: السرية والسلامة والتوافر



شكل 1.1: ثلاث السرية والسلامة والتوافر

يتفق المختصون على أن حماية المعلومات تعني الحفاظ على ثلاث خصائص أساسية يُعرف مجموعها بثلاث السرية والسلامة والتوافر (CIA Triad)،

وكل خاصية منها تجيب عن سؤال مختلف، فالسرية (Confidentiality) تجيب عن سؤال من يحق له أن يرى هذه المعلومة، والسلامة (Integrity) تجيب عن سؤال هل هذه المعلومة صحيحة ولم تُغيّر دون إذن، والتوافر (Availability) يجيب عن سؤال هل المعلومة موجودة حين نحتاجها.

وتُنتهك السرية حين يطلع على المعلومة من لا يحق له ذلك، سواء كان مهاجماً سرق قاعدة بيانات العملاء أو موظفاً فضولياً فتح ملف زميله الطبي أو جهازاً ضاع في سيارة أجرة وفيه نسخة غير مشفرة من العقود، وتشمل أدوات حفظ السرية التشفير وضبط الصلاحيات وتصنيف المعلومات والتدريب على عدم إفشاءها.

وتُنتهك السلامة حين تُغيّر المعلومة أو تُحذف أو تُفبرك دون صلاحية، كأن يعدل موظف رصيداً في النظام أو يغير مهاجم رقم الحساب في فاتورة مرسلة بالبريد لتذهب الحوالة إلى حسابه هو، وقد تُنتهك السلامة دون نية خبيثة خطأً في البرمجة يفسد السجلات أو عطل في القرص، وتشمل أدوات حفظ السلامة دوال التجزئة (Hash Functions) والتوقيع الرقمي وسجلات التدقيق والفصل بين المهام وضوابط التحقق من المدخلات.

ويُنتهك التوافر حين تصبح المعلومة أو الخدمة غير متاحة في الوقت الذي يحتاجها فيه أصحابها، كهجوم حجب الخدمة الذي يعطل بوابة حكومية في موسم تقديم الطلبات أو برمجية فدية تغلق نظام مستشفى أو انقطاع كهرباء في مركز بيانات بلا مولد احتياطي، وتشمل أدوات حفظ التوافر التكرار (Redundancy) والنسخ الاحتياطي وخطط الاستمرارية والحماية من حجب الخدمة.

ولا يعني الثالث أن الخصائص الثلاث متساوية الأهمية في كل سياق، فالسرية هي الأولوية القصوى في بيانات الاستخبارات، بينما يتقدم التوافر في أنظمة التحكم الصناعي التي يعني توقفها خطراً على الأرواح، وتتقدم السلامة

في الأنظمة المالية التي يهدد التلاعب بها الثقة كلها، ولهذا تبدأ أي حماية جادة بسؤال بسيط عن الخاصية التي يضر فقدانها أكثر من غيرها في هذا النظام تحديداً.

وقد أضاف المختصون إلى الثالوث خصائص مكملة يرد ذكرها كثيراً في المعايير والعقود، وهي الأصالة (Authenticity) أي التأكد من أن المعلومة صادرة فعلاً عن يدعي إصدارها، وعدم الإنكار (Non-repudiation) أي عجز الطرف عن إنكار فعل قام به كتوقيع عقد أو إرسال أمر تحويل، والمساءلة (Accountability) أي إمكانية نسبة كل فعل في النظام إلى شخص محدد، والخصوصية (Privacy) أي حق الأفراد في التحكم بمعلوماتهم الشخصية، وهو ما أصبح له في دول الخليج أنظمة وقوانين خاصة سنفصلها في فصل أمن البيانات.

جدول 1.1: الخصائص الثلاث وما يحفظها

الخاصية	السؤال الذي تجيب عنه	مثال على انتهاكها	ضوابط نموذجية
السرية	من يحق له الاطلاع	تسريب قاعدة بيانات العملاء	التشفير وضبط الصلاحيات والتصنيف
السلامة	هل المعلومة صحيحة وغير معدلة	تغيير رقم حساب في فاتورة	التجزئة والتوقيع الرقمي وسجلات التدقيق
التوافر	هل المعلومة متاحة وقت الحاجة	تعطل بوابة خدمات في موسم الذروة	التكرار والنسخ الاحتياطي وخطط الاستمرارية

3.1 أمن المعلومات والأمن السيبراني وحماية البيانات

تداخل هذه المصطلحات الثلاثة في الاستخدام اليومي حتى يظنها كثيرون شيئاً واحداً، غير أن لكل منها نطاقاً مختلفاً، فأمن المعلومات (Information Security) هو المظلة الأوسع لأنه يُعنى بحماية المعلومات في أي شكل كانت رقمية أو ورقية أو شفوية، أما الأمن السيبراني (Cybersecurity) فيركز على حماية الأنظمة الرقمية والشبكات والبيانات التي تمر عبرها من الهجمات الإلكترونية، فهو جزء من أمن المعلومات وإن كان الجزء الأكبر والأكثر حضوراً في عصرنا، وأما حماية البيانات (Data Protection) فتتفرع إلى المسألة من زاوية الحقوق والقانون، أي حق الفرد في أن تُجمع بياناته الشخصية وتُعالج وتُحفظ وفق قواعد واضحة تحترم خصوصيته.

ويساعد التمييز بين النطاقات الثلاثة على تحديد المسؤوليات داخل المؤسسة، فحماية الوثيقة الورقية في الأرشيف من الحريق والسرقة مسؤولية أمن المعلومات ولا علاقة لها بالشبكة، وصدد هجوم على الموقع الإلكتروني عمل سيبراني بحت، والإجابة عن سؤال هل يحق لنا الاحتفاظ ببيانات هذا العميل بعد انتهاء تعامله معنا سؤال في حماية البيانات يجب عنه القانون والسياسة قبل التقنية، وفي الممارسة العملية تلتقي النطاقات الثلاثة في برنامج واحد يقوده الرئيس التنفيذي لأمن المعلومات (CISO) بالتعاون مع مسؤول حماية البيانات والمختصين القانونيين.

4.1 المفردات الأربع: الأصل والتهديد والثغرة والخطر

يتحدث المختصون بلغة تقوم على أربعة مصطلحات لا بد من إتقانها قبل أي شيء آخر، فالأصل (Asset) هو كل ما له قيمة للمؤسسة ويحتاج إلى حماية، وقد

يكون معلومة كقاعدة بيانات أو نظاماً تكّاد أو خدمة كالبوابة الإلكترونية أو إنساناً كموظف يحمل معرفة لا يملكها غيره أو سمعة يصعب استعادتها، والتهديد (Threat) هو أي حدث أو فاعل يمكن أن يلحق الضرر بالأصل سواء كان مهاجماً أو موظفاً مهماً أو حريقاً أو عطلاً، والثغرة (Vulnerability) هي نقطة الضعف في الأصل أو في حمايته التي تتيح للتهديد أن يحقق ضرره كبرمجية لم تُحدّث أو كلمة مرور ضعيفة أو منفذ خادم مفتوح، والخطر (Risk) هو احتمال أن يستغل تهديد ثغرة في أصل مضروباً في حجم الأثر الناتج عن ذلك.

ويمكن تلخيص العلاقة بينها في معادلة بسيطة تقول إن الخطر هو حاصل اجتماع التهديد مع الثغرة مع الأثر، فإذا غاب أحد الثلاثة غاب الخطر، فالثغرة في نظام لا يهدده أحد لا تمثل خطراً حقيقياً، والتهديد الذي لا يجد ثغرة يستغلها يبقى تهديداً نظرياً، والاستغلال الذي لا يترتب عليه أثر لا يستحق الموارد، وعلى هذه المعادلة يقوم علم إدارة المخاطر كله الذي انفصله في الفصل الثالث.

ويرتبط بهذه المفردات مصطلح الضابط (Control) وهو الإجراء الذي نتخذه لتقليل الخطر إما بإزالة الثغرة أو بالحد من التهديد أو بتخفيف الأثر، ومصطلح الخطر المتبقي (Residual Risk) وهو ما يبقى من الخطر بعد تطبيق الضوابط، لأن الخطر لا ينعدم أبداً مهما أنفقنا، وإنما نخفضه إلى مستوى تقبله المؤسسة وهي واعية بما تقبله.

5.1 مبادئ لا تتغير

تتغير التقنيات كل بضع سنوات لكن مبادئ الحماية ثابتة منذ عقود، وأول هذه المبادئ الدفاع في العمق (Defense in Depth) الذي يقضي بالاعتماد على طبقة حماية واحدة مهما كانت قوية، بل نبني طبقات متتابعة بحيث إذا

سقطت واحدة صدت التي بعدها، فالقلعة لها خندق وسور وأبراج وحرس وليس سوراً واحداً فقط، وثانيها مبدأ الامتياز الأدنى (Least Privilege) الذي يقضي ألا يُمنح أي شخص أو نظام من الصلاحيات إلا ما يحتاجه لأداء عمله ولا شيء أكثر، لأن كل صلاحية زائدة هي باب إضافي للمهاجم حين يستولي على ذلك الحساب.

وثالثها الفصل بين المهام (Segregation of Duties) الذي يمنع أن يكون الشخص الواحد قادراً على إتمام عملية حساسة من بدايتها إلى نهايتها وحده، فمن يُدخل أمر الدفع لا يعتمد، ومن يكتب البرنامج لا ينشره في بيئة الإنتاج، ورابعها افتراض الاختراق (Assume Breach) الذي يقضي بأن نصمم أنظمتنا على افتراض أن المهاجم موجود في الداخل فعلاً، فنراقب ونجزئ ونحد من الحركة بدل أن نطمئن إلى أن السور لم يُخترق بعد، ومن هذا المبدأ انبثق نموذج انعدام الثقة (Zero Trust) الذي نفصله في فصل الهوية.

وخامسها البساطة، لأن النظام المعقد يصعب فهمه وتأمينه ومراجعته، وكل تعقيد زائد يخفي ثغرة محتملة، وسادسها الأمن بالتصميم والأمن افتراضياً (Secure by Design and by Default)، أي أن تُبنى الحماية في المنتج منذ لحظة تصميمه وأن تكون إعداداته الأولية آمنة دون أن يحتاج المستخدم إلى ضبطها، لأن الحماية التي تُضاف في النهاية تكون أضعف وأعلى، وسابعها أن الإنسان جزء من النظام، فأقوى تشفير في العالم لا يحمي كلمة مرور كتبها صاحبها على ورقة ملصقة بالشاشة، ولذلك خصصنا لهذا الجانب فصلاً كاملاً.

6.1 أنواع الضوابط

تُصنف الضوابط من زاويتين، فمن زاوية طبيعتها تنقسم إلى ضوابط إدارية (Administrative) كالسياسات والإجراءات والتدريب والعقود، وضوابط تقنية (Technical) كالجدران النارية والتشفير وأنظمة كشف التسلل، وضوابط مادية (Physical) كالأبواب والكاميرات والحراسة والأقفال، ولا تكتمل حماية بغير الأنواع الثلاثة لأن الجدار الناري لا يمنع موظفاً من إدخال غريب إلى غرفة الخوادم، والسياسة المكتوبة لا تمنع هجوماً آلياً على الشبكة.

ومن زاوية وظيفتها تنقسم الضوابط إلى خمس وظائف، فالضابط الوقائي (Preventive) يمنع الحدث قبل وقوعه كالمصادقة متعددة العوامل، والضابط الكاشف (Detective) يكتشف الحدث حين يقع أو بعده كأنظمة المراقبة وسجلات التدقيق، والضابط التصحيحي (Corrective) يعالج أثر الحدث كاستعادة النسخ الاحتياطية، والضابط الرادع (Deterrent) يثني المهاجم عن المحاولة كلافئات التحذير والعقوبات المعلنة، والضابط التعويضي (Compensating) يحل محل ضابط أساسي تعذر تطبيقه كمراقبة مشددة لنظام قديم لا يمكن تحديثه.

جدول 2.1: وظائف الضوابط الخمس

الوظيفة	ماذا تفعل	أمثلة
وقائي	يمنع الحدث قبل وقوعه	المصادقة متعددة العوامل والتشفير
كاشف	يكتشف الحدث عند وقوعه	أنظمة كشف التسلل وسجلات التدقيق

الوظيفة	ماذا تفعل	أمثلة
تصحيحي	يعالج أثر الحدث	استعادة النسخ الاحتياطية
رادع	يثني عن المحاولة	التحذيرات والعقوبات المعلنة
تعويضي	يحل محل ضابط متعذر	مراقبة مشددة لنظام قديم

7.1 لماذا تُخترق المؤسسات رغم كل هذا

تكشف تحقيقات الحوادث عاماً بعد عام أن معظم الاختراقات لا تقع بسبب تقنيات هجوم متقدمة بل بسبب أخطاء معروفة، فثغرة لم تُرقّع مع أن تحديثها متاح منذ شهور، وحساب يحمل صلاحيات مدير بكلمة مرور تُستخدم في موقع آخر تسربت منه، وخدمة سحابية تُركت مفتوحة للجميع بإعداد خاطئ، وموظف ضغط على رابط في رسالة بدت من مديره، ومورد خارجي يملك وصولاً إلى الشبكة دون أن يعرف أحد ما يفعله به، وغياب شبه كامل للرؤية بحيث يبقى المهاجم في الشبكة أسابيع قبل أن يلاحظه أحد.

والقاسم المشترك بين هذه الأسباب أنها ليست مشكلات تقنية صرفة بل مشكلات في الإدارة والثقافة والانضباط، فالمؤسسة التي تعرف أصولها وتصنفها وتحديث أنظمتها وتضبط صلاحياتها وتراقب شبكتها وتدريب موظفيها تصد الغالبية العظمى من الهجمات بأدوات متاحة للجميع، أما المؤسسة التي تشتري أعلى المنتجات دون هذه الأساسيات فهي تضع قفلاً ذهبياً على باب مفتوح.

8.1 الأمن عملية مستمرة لا منتج يُشترى

يُختم هذا الفصل بالفكرة التي تحكم الكتاب كله، وهي أن أمن المعلومات ليس حالة تصل إليها المؤسسة ثم تستريح، بل عملية دائرية لا تتوقف لأن الأصول تتغير والتهديدات تتطور والثغرات تُكتشف كل يوم، ويلخص إطار الأمن السيبراني الصادر عن المعهد الوطني الأمريكي للمعايير والتقنية (NIST CSF) هذه العملية في وظائف متتابعة تبدأ بالحكمة ثم تحديد الأصول والمخاطر ثم الحماية ثم الكشف ثم الاستجابة ثم التعافي، وتعود الدائرة إلى بدايتها بما تعلمته المؤسسة من كل جولة، وعلى هذا الترتيب تقريباً بنيت أبواب هذا الكتاب.

9.1 خلاصة الفصل

- المعلومات أصل له قيمة وتوجد في ثلاث حالات هي التخزين والنقل والاستخدام، وتمر بدورة حياة من الإنشاء إلى الإتلاف
- نحجي ثلاث خصائص هي السرية والسلامة والتوافر، وتضاف إليها الأصالة وعدم الإنكار والمساءلة والخصوصية
- أمن المعلومات مظلة أوسع من الأمن السيبراني، بينما تنظر حماية البيانات من زاوية الحقوق والقانون
- الخطر هو اجتماع تهديد مع ثغرة في أصل مع أثر، والضوابط تخفضه إلى خطر متبقي مقبول
- المبادئ الثابتة هي الدفاع في العمق والامتياز الأدنى والفصل بين المهام واقتراض الاختراق والبساطة والأمن بالتصميم
- الضوابط إدارية وتقنية ومادية بطبيعتها، ووقائية وكاشفة وتصحيحية وراعية وتوعوية بوظيفتها

10.1 المصطلحات الأساسية

المصطلح	بالإنجليزية
السرية	Confidentiality
السلامة	Integrity
التوافر	Availability
عدم الإنكار	Non-repudiation
الأصل	Asset
التهديد	Threat
الثغرة	Vulnerability
الخطر	Risk
الضابط	Control
الخطر المتبقي	Residual Risk
الدفاع في العمق	Defense in Depth
الامتياز الأدنى	Least Privilege

11.1 خريطة إلى الأطر

يؤسس هذا الفصل للمفاهيم التي تقوم عليها كل الأطر، فالخصائص الثلاث هي تعريف أمن المعلومات في المعيار الدولي ISO/IEC 27000، ودورة الوظائف من الحكومة إلى التعافي هي بنية إطار NIST CSF في إصداره الثاني، ومفردات الأصل والتهديد والثغرة والخطر هي لغة فصول إدارة المخاطر في الأطر الخلية كلها.

12.1 أسئلة للمراجعة

1. ما الفرق بين البيانات والمعلومات والمعرفة، وأيها نحي؟
2. اذكر نظاماً يتقدم فيه السلامة على السرية وعلل اختيارك؟
3. لماذا لا يكفي ضابط وقائي واحد مهما كانت قوته؟
4. ما الخطر المتبقي ومن يقرر قبوله؟
5. صنف الضوابط الآتية بطبيعتها ووظيفتها: كاميرا المراقبة، وسياسة كلمات المرور، ونظام النسخ الاحتياطي، وتشفير القرص؟
6. لماذا يوصف أمن المعلومات بأنه عملية لا منتج؟

13.1 تمارين تطبيقية

1. اختر نظاماً تتعامل معه يومياً كتطبيق البنك أو بوابة الجامعة، وحدد لكل خاصية من الخصائص الثلاث مثلاً على انتهاكها وأثر ذلك عليك
2. أعد قائمة بعشرة أصول في مؤسسة صغيرة تخيلها وصنف كل أصل بحسب الخاصية التي يضر فقدانها أكثر
3. صنف خمسة عشر ضابطاً تعرفها في جدول من بعدين هما الطبيعة والوظيفة ولاحظ الخانات الفارغة

مدخل إلى أمن المعلومات